

L2 - 3.5. Slingshot

Slingshot Inc., a leading toy company, has recently detected suspicious activity on its e-commerce web server and potential unauthorized modifications to its database. To investigate the incident, you have been brought in to analyze the available logs and determine the scope and impact of the attack. To aid in your investigation, you've been provided with access to an Elastic Stack instance containing logs from the suspected compromise. Below are the credentials required to access the Kibana dashboard. Slingshot's IT team noted that the suspicious activity began on **July 26, 2023**.



Task - The Slingshot Investigation

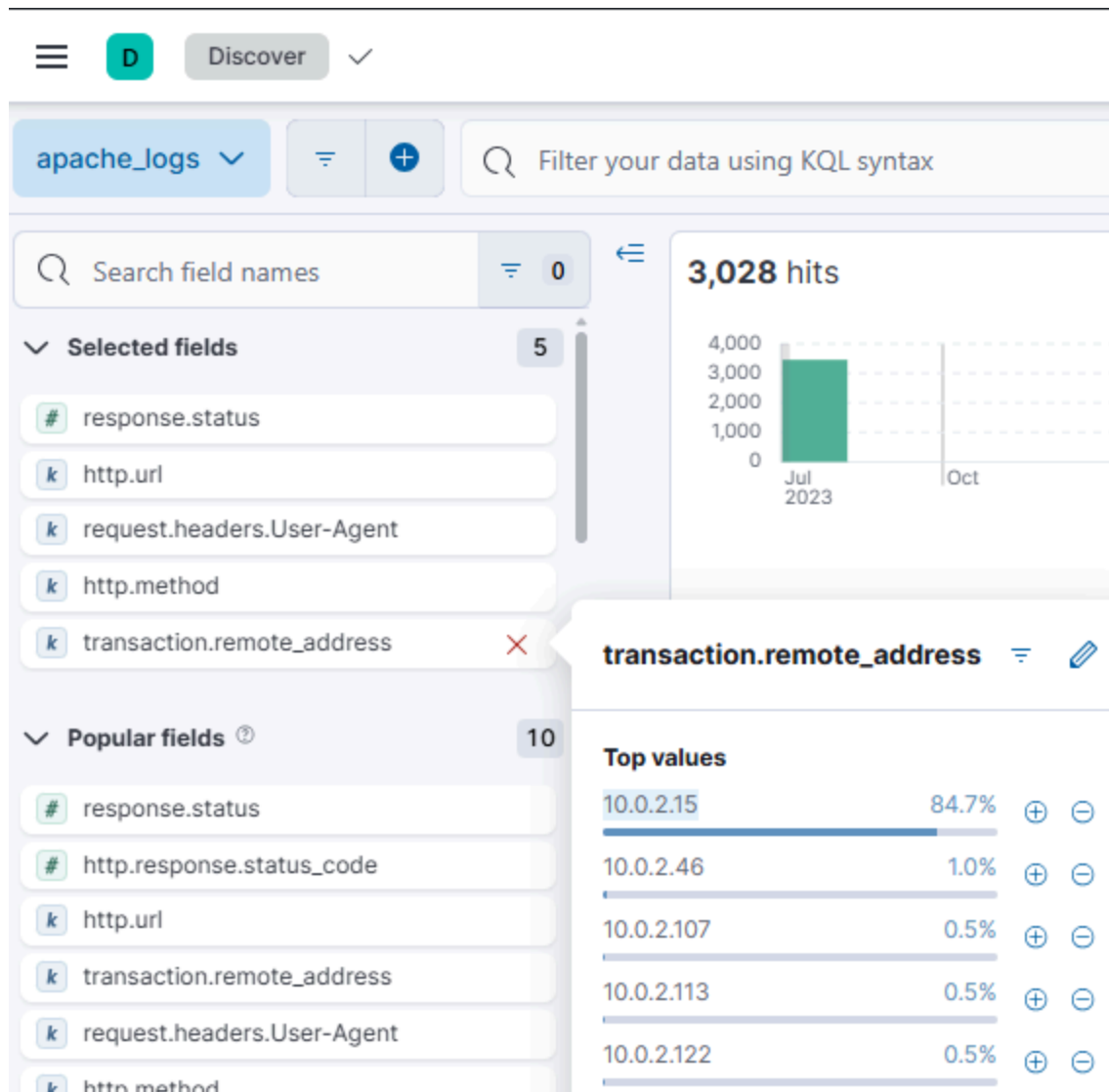
Once you've accessed the Kibana homepage, head to Discover to begin your investigation. A premade Data view has been set up with all the log data needed to uncover potential suspicious activity.

1. Ensure you're using the `apache_logs` Data view
2. Set the time frame from `Jul 26, 2023 @ 00:00:00.000 → now`
3. Investigate the event data

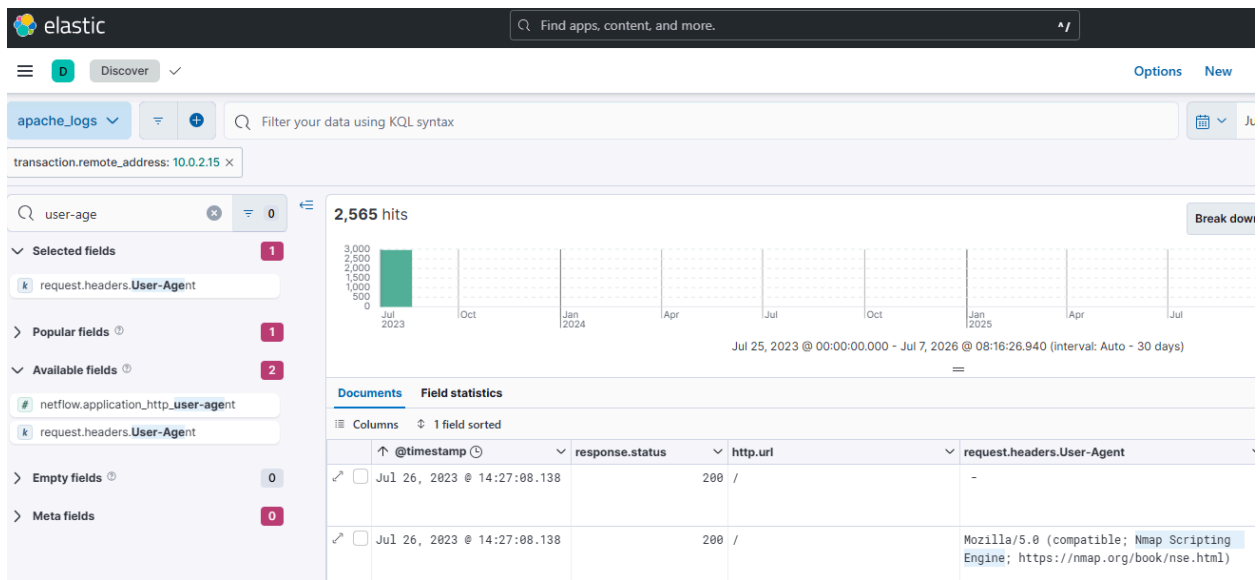


Answer the questions below

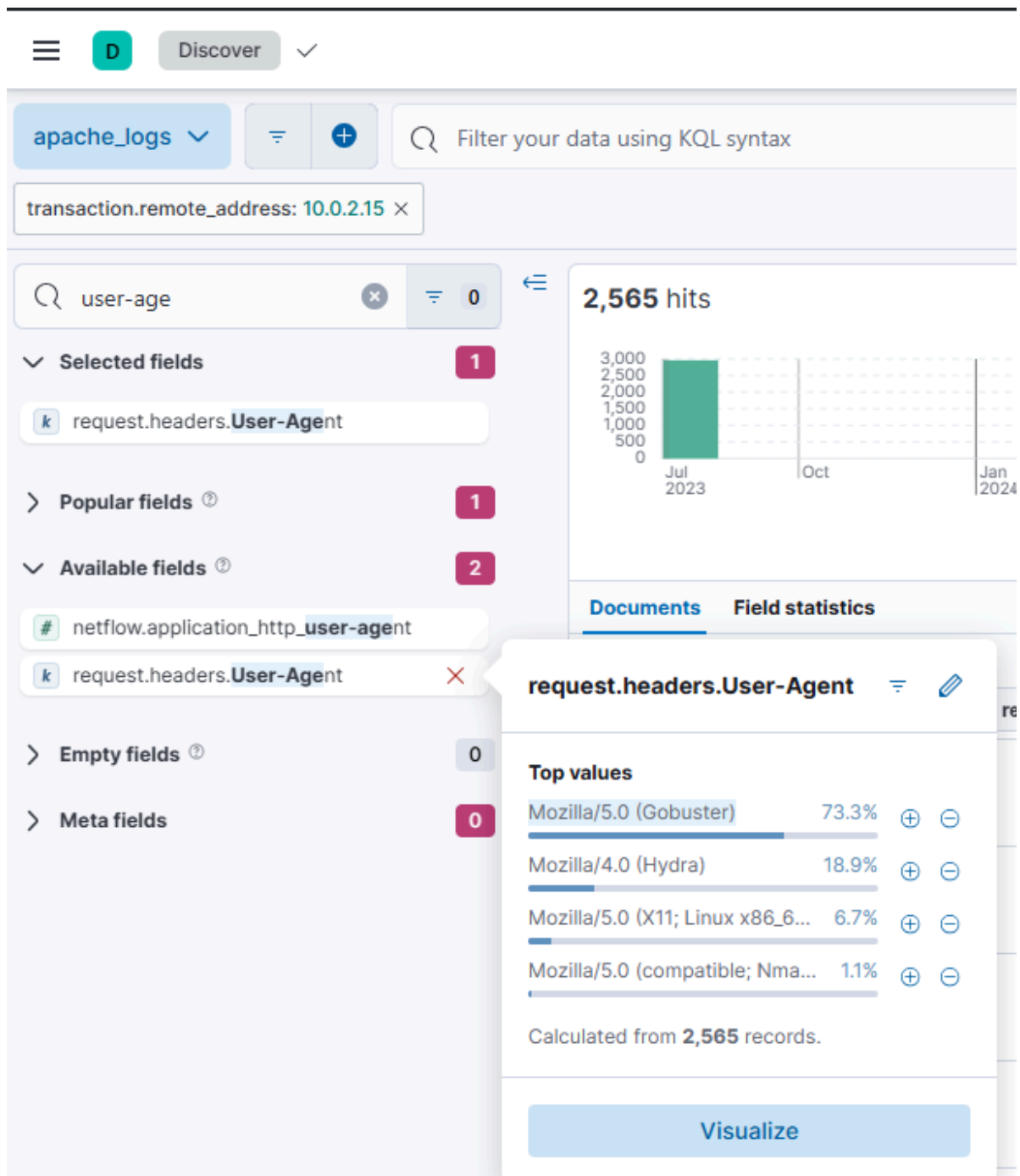
What is the attacker's IP address? 10.0.2.15



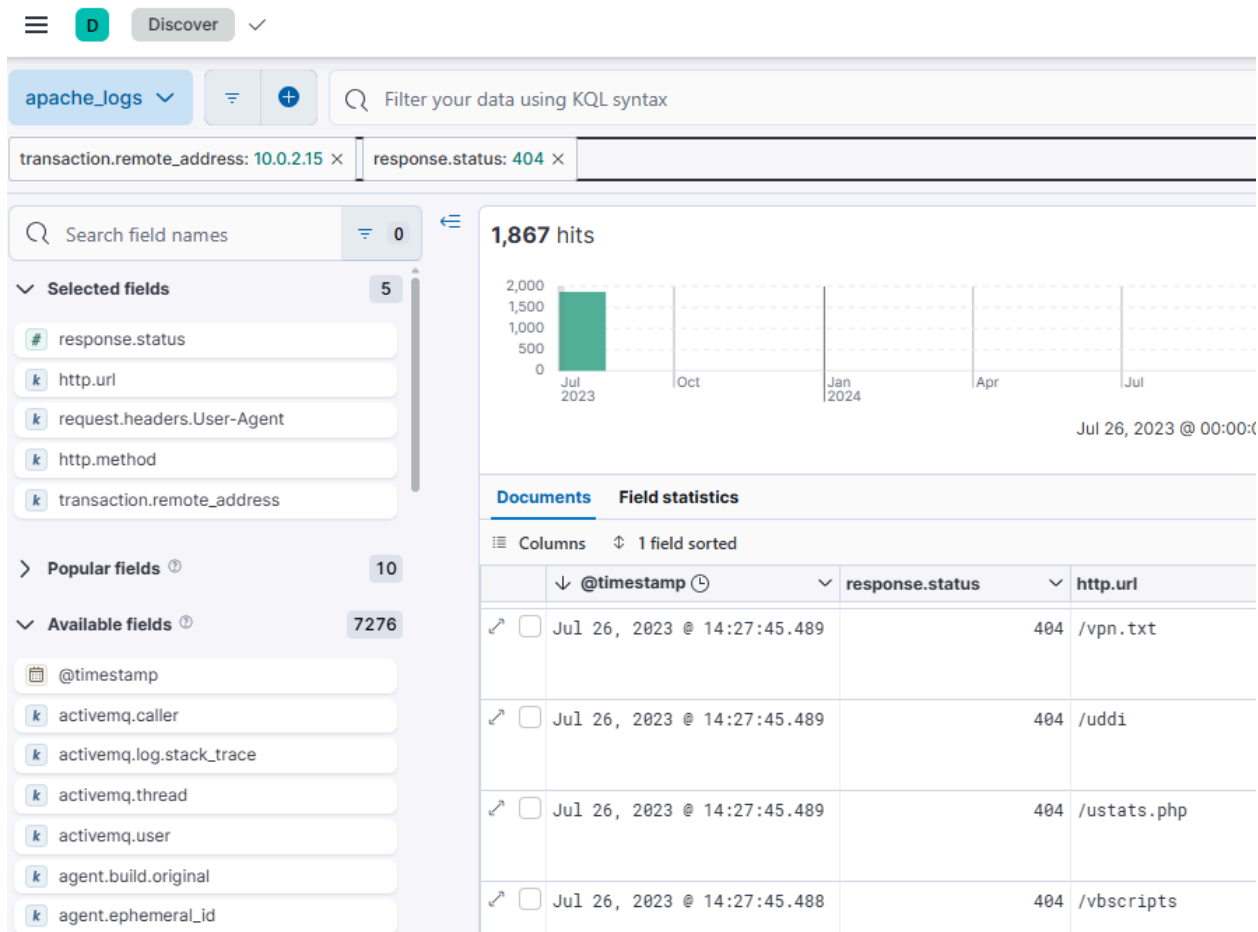
What is the first scanner that the attacker ran against the web server? Nmap Scripting Engine



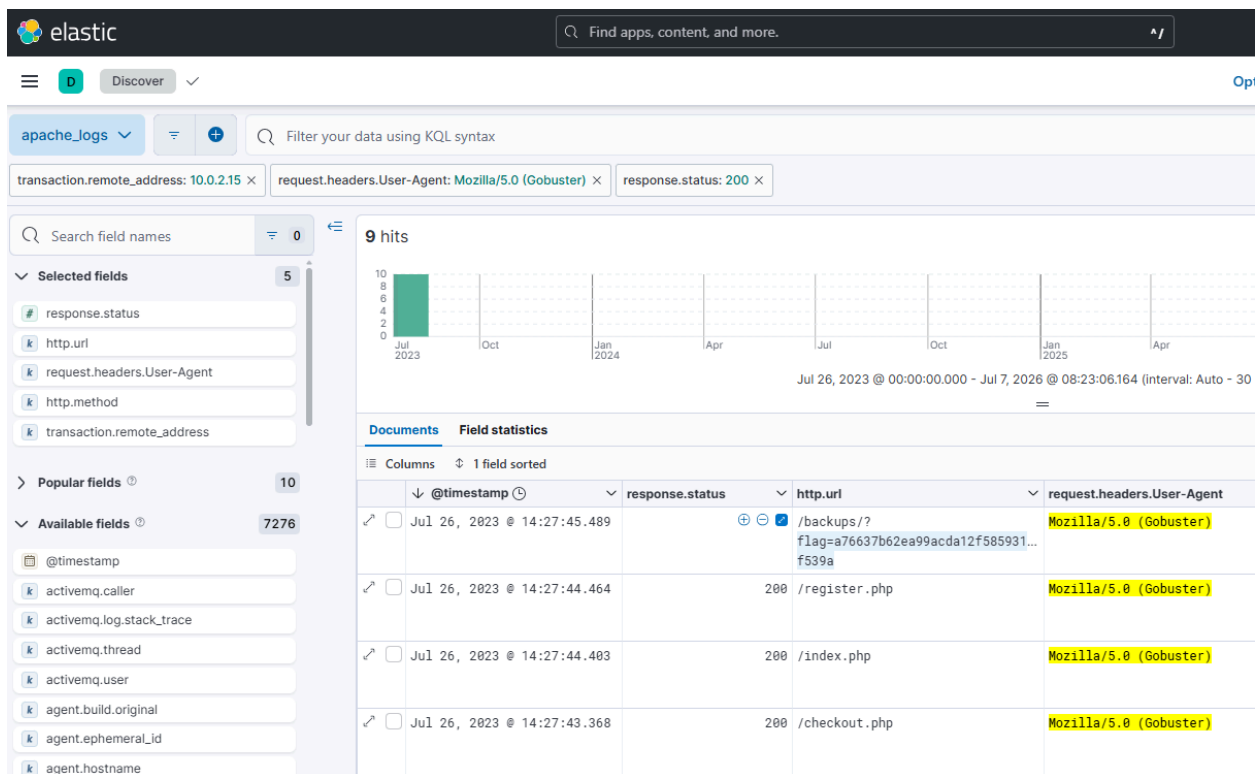
What is the User Agent of the directory enumeration tool that the attacker used on the web server? Mozilla/5.0 (Gobuster)



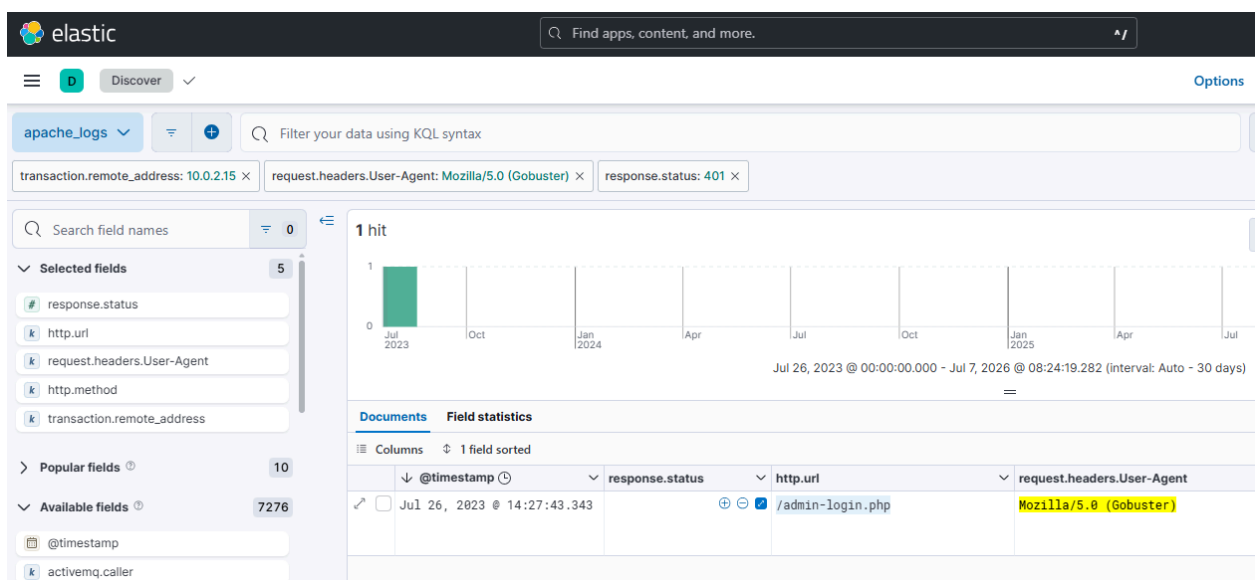
In total, how many 404 responses did the attacker receive when enumerating the web server? 1867



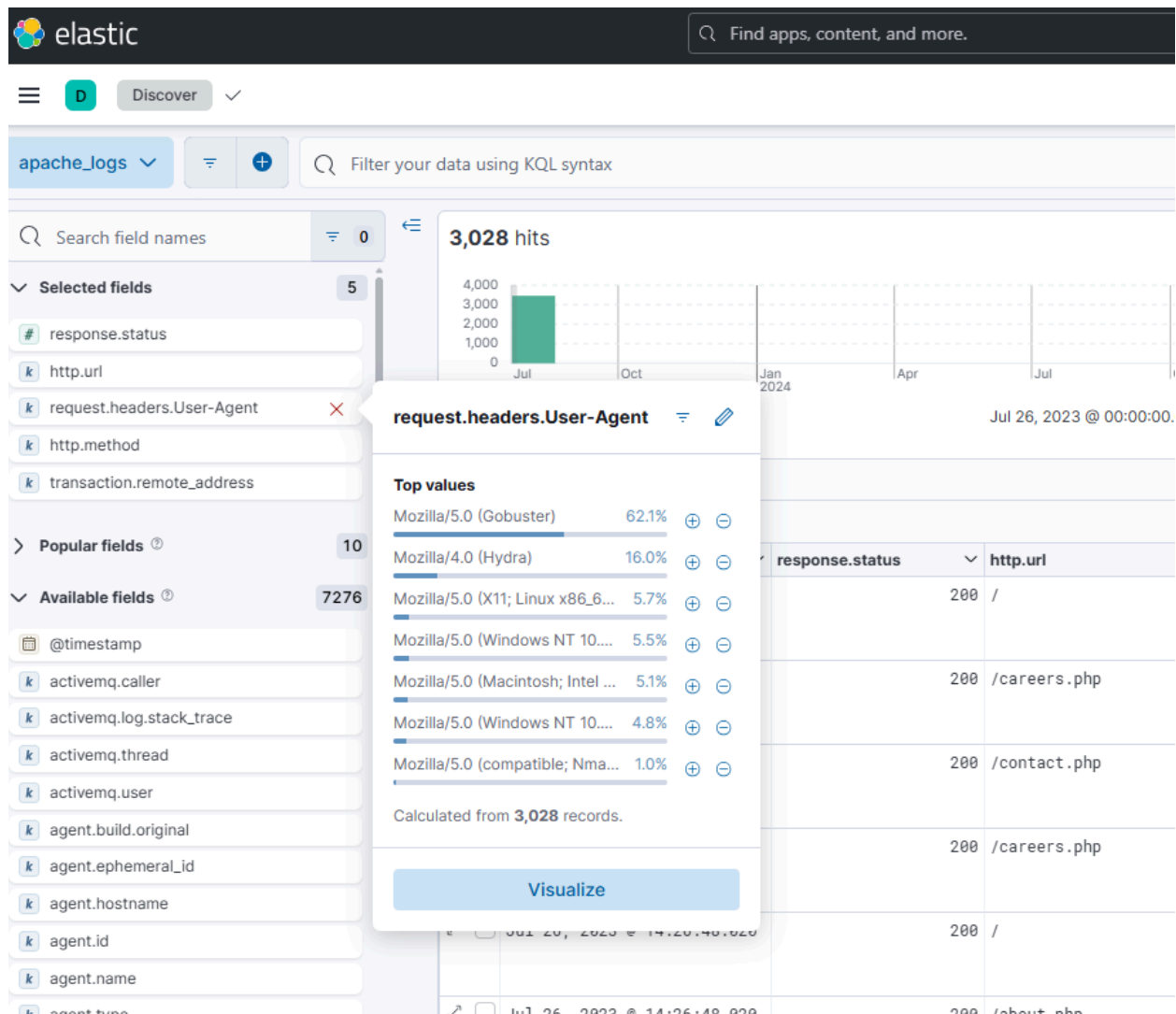
What flag was discovered in one of the directories identified during enumeration? a76637b62ea99acda12f5859313f539a (A HTTP response status 200 **The request was successful**)



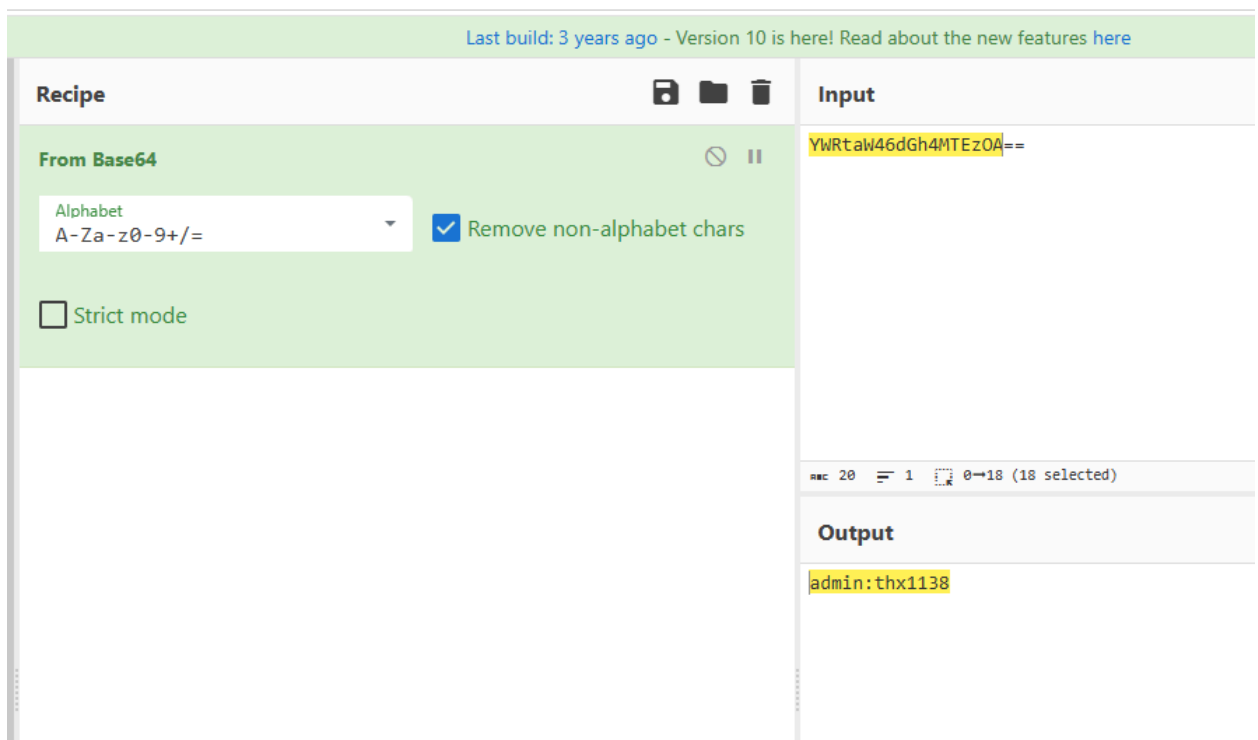
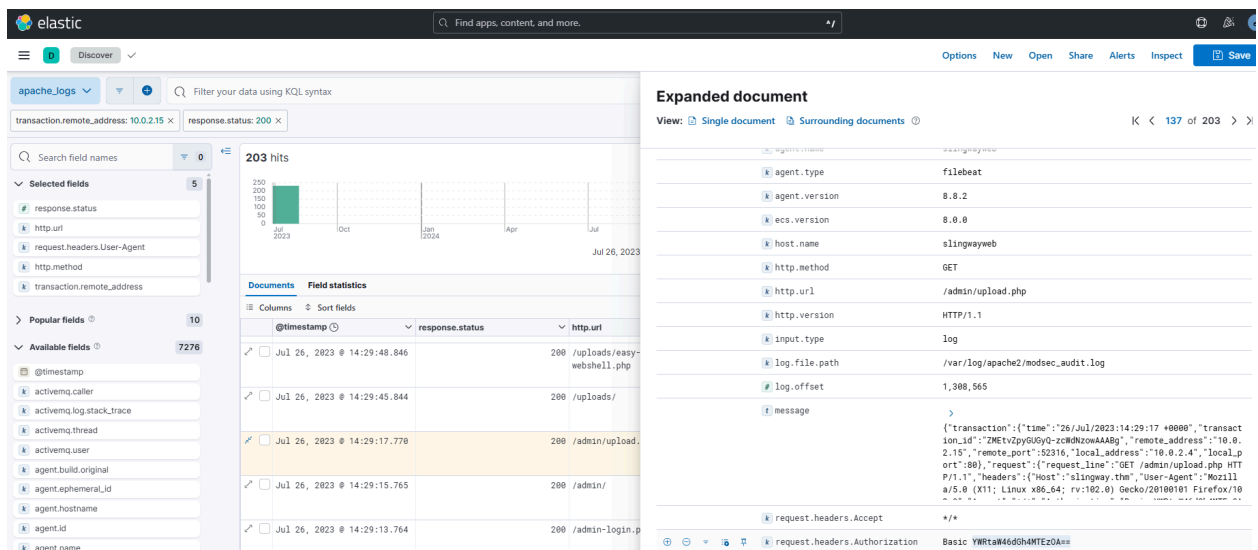
What login page did the attacker discover using the directory enumeration tool?
 /admin-login.php (A HTTP response status 401 **Unauthorized — authentication is required or has failed.**)



What is the User-Agent of the brute-force tool that the attacker used on the admin panel? Mozilla/4.0 (Hydra)



What `username:password` combination did the attacker use to gain access to the admin page? admin:thx1138



What flag was included in the file that the attacker uploaded to the `/admin/upload.php` directory?

THM{ecb012e53a58818cbd17a924769ec447} (A HTTP response status 404 means **Not Found** — the server could not find the requested resource.S

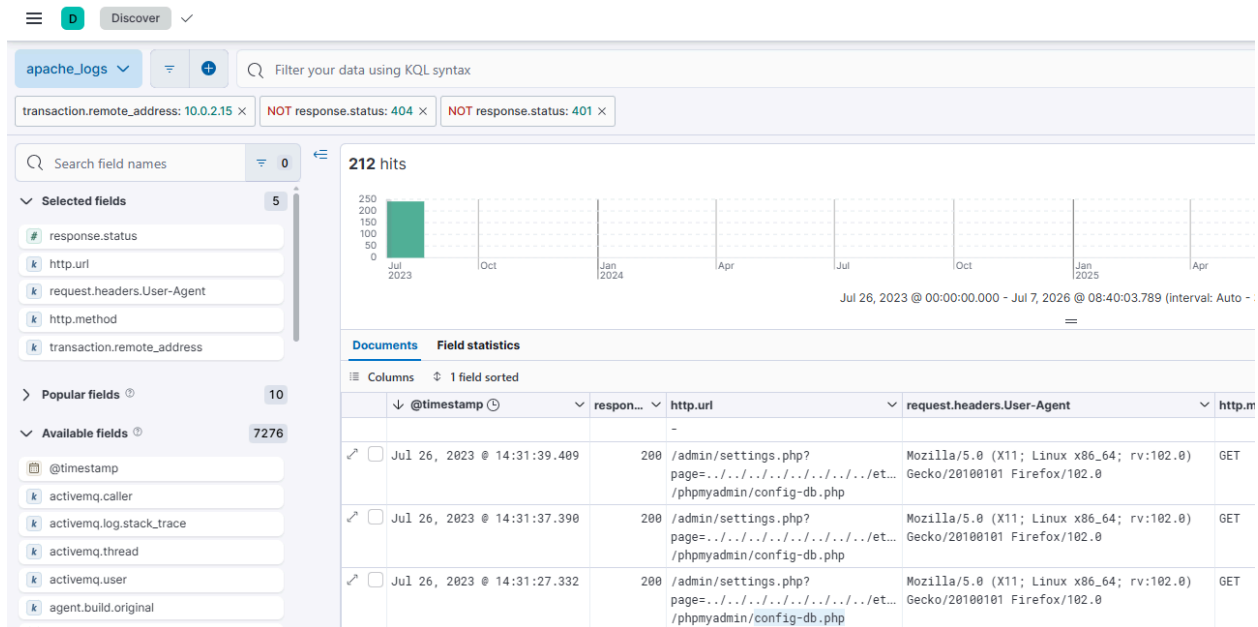
The screenshot shows the Elastic Discover interface. The search query is `transaction.remote_address: 10.0.2.15` with filters `NOT response.status: 404` and `NOT response.status: 401`. The results table shows 212 hits. One hit is highlighted with a 200 status code and a request to `/admin/upload.php?action=upload`. The expanded document view on the right shows the full request body, which is a multipart/form-data request containing a file named `easy-simple-php-webshell.php`.

What was the first command the attacker ran using the web shell?

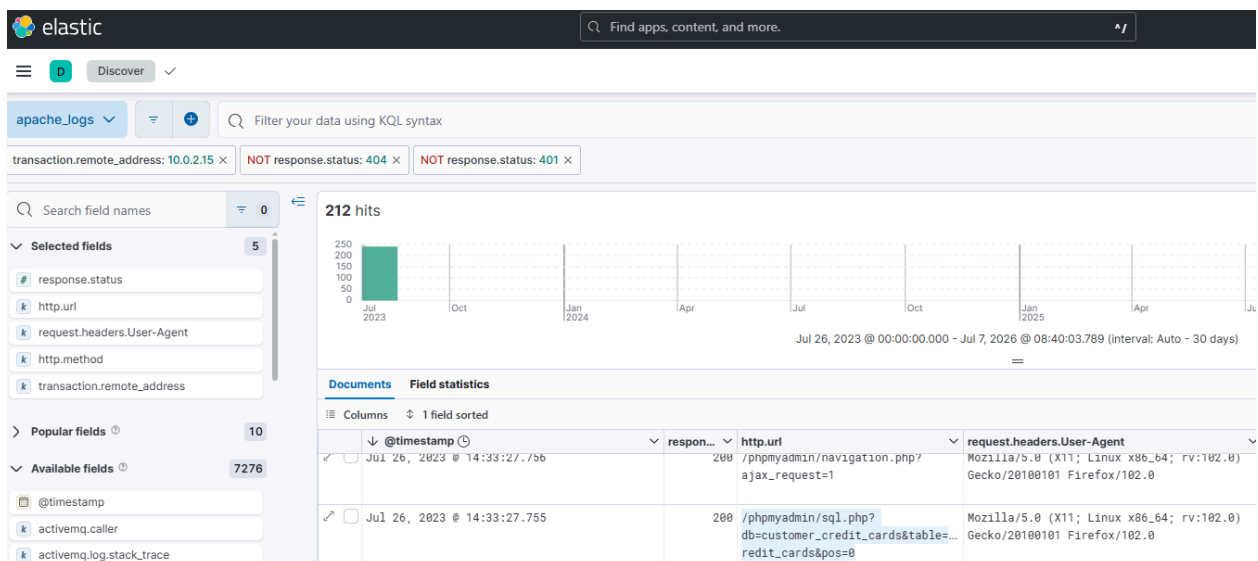
whoami (attackers often probe admin panchat gptels and upload functionality. A **200 response** or a successful upload request would be much more important than hundreds of failed 404/401 attempts. So the filter was used to reduce noise and focus on meaningful events during threat hunting.

The screenshot shows the Elastic Discover interface. The search query is `transaction.remote_address: 10.0.2.15` with filters `NOT response.status: 404` and `NOT response.status: 401`. The results table shows 212 hits. One hit is highlighted with a 200 status code and a request to `/uploads/easy-simple-php-webshell.php?cmd=whoami`. The expanded document view on the right shows the full request body, which is a multipart/form-data request containing a file named `easy-simple-php-webshell.php`.

Which file was accessed via Local File Inclusion (LFI) to retrieve database credentials? config-db.php



What is the name of the database the attacker exported via `/phpmyadmin` ?
customer_credit_cards



What flag does the attacker insert into the database using import.php?
c6aa3215a7d519eeb40a660f3b76e64c

RecipeInput

URL Decode

```

Type: "application/x-www-form-urlencoded; charset=UTF-8", "X-Requested-With": "XMLHttpRequest", "Content-
Length": "290", "Origin": "http://slingway.thm", "Connection": "keep-alive", "Cookie": "pma_lang=en; pmaUser=1-
k7b8221vKz2X3A2Zp102G3Y1EBtBvYvjq0HfH5CKZ2FTQ830X3Dk2Zk2Z2macK22X3A2Z2fd7226470405df1a9548cac890a51d662f112ceK22X2
Kz2ZpayloadK22X3A2Z2X5CKZ2Fk7YUyet982nf6sPsEloagK30X3Dk2Z2K7D; phpMyAdmin=esa6gng8pvn5dlot5gubbs1as; pmaAuth=1-
k7b8221vKz2X3A2Z21e9LVke0X5CKZ2F70oYnh31YXhg830X3Dk2Zk2Z2macK22X3A2Z282fd7b75ce678964befbd37c74e53741d2c914272K22X2
Kz2ZpayloadK22X3A2Z291KvcaHfC7a7mFhLS52z1T7K86412tHwEGYMS6J8X3Dk2Z2K7D"; "body":
["sql_query=INSERT INTO `00`credit_cards`00`
(`00`card_number`00`K2C+`00`cardholder_name`00`K2C+`00`expiration_date`00`K2C+`00`cvv`00`)VALUES(
'000`K2C+`c6aa3215a7d519eeb40a60f3b76e64`K2C+`000`K2C+`000`K3B8server=1n0 history=true&00`nocache=16903820783858094
65&token=302e562342127c5d625834422294172`"]}, "response": {"protocol": "HTTP/1.1", "status": 200, "headers": {"Set-
Cookie": "phpMyAdmin=esa6gng8pvn5dlot5gubbs1as; path=/phpmyadmin/; HttpOnly"; HttpOnly"; Expires": "Wed, 26 Jul 2023 14:34:38
+0000"; "Cache-Control": "no-store, no-cache, must-revalidate, pre-check=0, post-check=0, max-age=0"; "Last-
-Modified": "2023-07-26T14:34:38+00:00"}

```

Output

☐ match case
 ☐ regex
 ☐ word

```

Length: "290", "Origin": "http://slingway.thm", "Connection": "keep-alive", "Cookie": "pma_lang=en; pmaUser=1-
k7b8221vKz2X3A2Zp102G3Y1EBtBvYvjq0HfH5CKZ2FTQ830X3Dk2Zk2Z2macK22X3A2Z2fd7226470405df1a9548cac890a51d662f112ce", "payload": "\k7Yuet982nf6sPsEloag=
"; phpMyAdmin=esa6gng8pvn5dlot5gubbs1as; pmaAuth=1-
k7b8221vKz2X3A2Z21e9LVke0X5CKZ2F70oYnh31YXhg830X3Dk2Zk2Z2macK22X3A2Z282fd7b75ce678964befbd37c74e53741d2c914272", "payload": "91kKCVaHfC7a7mFhLS52z1T
7K86412tHwEGYMS6J8X3Dk2Z2K7D"; "body": ["sql_query=INSERT INTO `credit_cards` (`card_number`, `cardholder_name`,
`expiration_date`, `cvv`) VALUES ('000', 'c6aa3215a7d519eeb40a60f3b76e64', '000',
'000');&server=1n0 history=true&00`nocache=1690382078385809465&token=302e562342127c5d625834422294172`"]}, "response":

```